

WYDZIAŁ INFORMATYKI I TELEKOMUNIKACJI  
Instytut Informatyki

Praca dyplomowa magisterska

**ANALIZA RUCHU SIECIOWEGO APLIKACJI MOBILNYCH NA  
PLATFORMIE ANDROID**

Mikołaj Kmieciak, nr albumu 147575

Promotor  
dr inż. dr inż. Michał Kalewski

POZNAŃ 2025

## Streszczenie

Przedmiotem pracy jest analiza ruchu sieciowego generowanego przez wybrane aplikacje mobilne systemu Android. Zaimplementowano środowisko przechwytywania (mitmproxy, tcpdump), normalizacji i klasyfikacji z uwzględnieniem protokołów (HTTP/1.1, HTTP/2, QUIC), szyfrowania TLS oraz aspektów prywatności (domeny trackingowe, identyfikatory). Wyniki obejmują statystyki protokołów, charakterystykę ruchu według kategorii aplikacji oraz ocenę ryzyk potencjalnego ujawniania metadanych.

**Słowa kluczowe:** Android, analiza ruchu, TLS, QUIC, prywatność, mitmproxy.

## Abstract

This thesis investigates network traffic generated by selected Android applications. A modular environment for traffic interception (mitmproxy, tcpdump), normalization and classification was implemented, focusing on protocols (HTTP/1.1, HTTP/2, QUIC), TLS encryption and privacy aspects (tracking domains, identifiers). Results include protocol usage statistics, traffic characteristics across app categories, and an assessment of potential metadata exposure risks.

**Keywords:** Android, network traffic analysis, TLS, QUIC, privacy, mitmproxy.

# Spis treści

|          |                                                             |          |
|----------|-------------------------------------------------------------|----------|
| <b>1</b> | <b>Eksperymenty: studia przypadków (PCAPdroid + Exodus)</b> | <b>5</b> |
| 1.1      | Cel i założenia . . . . .                                   | 5        |
| 1.2      | Procedura (pojedyncza iteracja) . . . . .                   | 5        |
| 1.3      | Instagram (wersja 394.0.0.46.81) . . . . .                  | 6        |
| 1.3.1    | Wolumen i liczność wg protokołu . . . . .                   | 6        |
| 1.3.2    | Największe cele (IP/port) wg wolumenu . . . . .             | 6        |
| 1.3.3    | Najczęstsze hosty (liczba przepływów) . . . . .             | 7        |
| 1.3.4    | Obserwacje jakościowe . . . . .                             | 7        |
| 1.3.5    | Wyniki z Exodus Privacy [1] . . . . .                       | 7        |
| 1.3.6    | Subiektywne spostrzeżenia . . . . .                         | 8        |
| 1.3.7    | Podsumowanie . . . . .                                      | 8        |
| 1.4      | Facebook (wersja 526.1.0.66.75) . . . . .                   | 9        |
| 1.4.1    | Wolumen i liczność wg protokołu . . . . .                   | 9        |
| 1.4.2    | Największe cele (IP/port) wg wolumenu . . . . .             | 9        |
| 1.4.3    | Najczęstsze hosty (liczba przepływów) . . . . .             | 10       |
| 1.4.4    | Wyniki z Exodus Privacy (aplikacja) . . . . .               | 10       |
| 1.4.5    | Subiektywne spostrzeżenia . . . . .                         | 11       |
| 1.4.6    | Podsumowanie . . . . .                                      | 11       |
| 1.5      | Posnania (wersja 1.1.1) . . . . .                           | 12       |
| 1.5.1    | Wolumen i liczność wg protokołu . . . . .                   | 12       |
| 1.5.2    | Największe cele (IP/port) wg wolumenu . . . . .             | 12       |
| 1.5.3    | Najczęstsze hosty (liczba przepływów) . . . . .             | 12       |
| 1.5.4    | Obserwacje jakościowe . . . . .                             | 13       |
| 1.5.5    | Wyniki z Exodus Privacy [1] . . . . .                       | 13       |
| 1.5.6    | Subiektywne spostrzeżenia . . . . .                         | 13       |
| 1.5.7    | Podsumowanie . . . . .                                      | 13       |
| 1.6      | mObywatel (wersja 4.64.0 (4899)) . . . . .                  | 14       |
| 1.6.1    | Wolumen i liczność wg protokołu . . . . .                   | 14       |
| 1.6.2    | Największe cele (IP/port) wg wolumenu . . . . .             | 14       |
| 1.6.3    | Najczęstsze hosty (liczba przepływów) . . . . .             | 14       |
| 1.6.4    | Obserwacje jakościowe . . . . .                             | 15       |
| 1.6.5    | Wyniki z Exodus Privacy [1] . . . . .                       | 15       |
| 1.6.6    | Subiektywne spostrzeżenia . . . . .                         | 15       |
| 1.6.7    | Podsumowanie . . . . .                                      | 16       |
| 1.7      | Mobile USOS (wersja 2.0.3) . . . . .                        | 17       |
| 1.7.1    | Wolumen i liczność wg protokołu . . . . .                   | 17       |
| 1.7.2    | Największe cele (IP/port) wg wolumenu . . . . .             | 17       |

|        |                                                 |    |
|--------|-------------------------------------------------|----|
| 1.7.3  | Najczęstsze hosty (liczba przepływów) . . . . . | 18 |
| 1.7.4  | Obserwacje jakościowe . . . . .                 | 18 |
| 1.7.5  | Wyniki z Exodus Privacy [1] . . . . .           | 18 |
| 1.7.6  | Subiektywne spostrzeżenia . . . . .             | 18 |
| 1.7.7  | Podsumowanie . . . . .                          | 19 |
| 1.8    | Spotify (wersja 9.0.72.967) . . . . .           | 20 |
| 1.8.1  | Wolumen i liczność wg protokołu . . . . .       | 20 |
| 1.8.2  | Największe cele (IP/port) wg wolumenu . . . . . | 20 |
| 1.8.3  | Najczęstsze hosty (liczba przepływów) . . . . . | 21 |
| 1.8.4  | Obserwacje jakościowe . . . . .                 | 21 |
| 1.8.5  | Wyniki z Exodus Privacy [1] . . . . .           | 21 |
| 1.8.6  | Subiektywne spostrzeżenia . . . . .             | 22 |
| 1.8.7  | Podsumowanie . . . . .                          | 22 |
| 1.9    | Voronoi (wersja 1.0.54) . . . . .               | 23 |
| 1.9.1  | Wolumen i liczność wg protokołu . . . . .       | 23 |
| 1.9.2  | Największe cele (IP/port) wg wolumenu . . . . . | 23 |
| 1.9.3  | Najczęstsze hosty (liczba przepływów) . . . . . | 24 |
| 1.9.4  | Obserwacje jakościowe . . . . .                 | 24 |
| 1.9.5  | Wyniki z Exodus Privacy [1] . . . . .           | 24 |
| 1.9.6  | Subiektywne spostrzeżenia . . . . .             | 25 |
| 1.9.7  | Podsumowanie . . . . .                          | 25 |
| 1.10   | TikTok (wersja 34.8.4) . . . . .                | 26 |
| 1.10.1 | Wolumen i liczność wg protokołu . . . . .       | 26 |
| 1.10.2 | Największe cele (IP/port) wg wolumenu . . . . . | 26 |
| 1.10.3 | Najczęstsze hosty (liczba przepływów) . . . . . | 27 |
| 1.10.4 | Obserwacje jakościowe . . . . .                 | 27 |
| 1.10.5 | Wyniki z Exodus Privacy [1] . . . . .           | 27 |
| 1.10.6 | Subiektywne spostrzeżenia . . . . .             | 27 |
| 1.10.7 | Podsumowanie . . . . .                          | 28 |

|                     |           |
|---------------------|-----------|
| <b>Bibliografia</b> | <b>29</b> |
|---------------------|-----------|

## Rozdział 1

# Eksperymenty: studia przypadków (PCAPdroid + Exodus)

### 1.1 Cel i założenia

Celem eksperymentu jest empiryczna charakterystyka komunikacji sieciowej wybranych aplikacji oraz zestawienie obserwacji z danymi o uprawnieniach i trackerach (metodologia *Exodus Privacy*). Interesują nas:

1. rejestracja ruchu z użyciem **PCAPdroid** (tryb VPN, eksport CSV/PCAPNG),
2. agregacja metryk (protokół, host, port, wolumen),
3. korelacja z analizą statyczną **Exodus Privacy** (trackery i uprawnienia).

### 1.2 Procedura (pojedyncza iteracja)

Zgodnie z metodyką, jedna iteracja ( $\approx 15$  min) składa się z:

1. **Baseline OS (2 min)** – aplikacja nieuruchomiona - punkt odniesienia dla tła.
2. **Cold start (1 min)** – uruchomienie i ustabilizowanie ekranu głównego.
3. **Nawigacja (2 min)** – główne ekrany (feed, profil, wyszukiwarka).
4. **Media/operacja (1 min)** – krótkie odtwarzanie/przewijanie, wymuszenie większych transferów.
5. **Offline/online (4 min)** – 2 min offline + 2 min po reconnect; obserwacja retry/backoff.
6. **Tło (10 min)** – obserwacja po zamknięciu aplikacji.

### 1.3 Instagram (wersja 394.0.0.46.81)

#### Okno i wolumen

Okno eksperymentu: **2025-08-18 17:55:47–18:08:00** ( $\approx 12.2$  min). Zarejestrowano **302** przepływy, wolumen  $\approx$  **28.04 MiB** (RX  $\approx$  **27.20 MiB**, TX  $\approx$  **0.85 MiB**).

#### 1.3.1 Wolumen i licznosc wg protokołu

TABELA 1.1: Podsumowanie wg protokołu (Instagram, ta sesja)

| Protokół     | Flows      | MiB (total)  | B wysłane      | B odebrane        |
|--------------|------------|--------------|----------------|-------------------|
| QUIC         | 187        | 27.99        | 855,220        | 28,500,436        |
| HTTPS        | 5          | 0.02         | 12,180         | 9,063             |
| TCP          | 12         | 0.02         | 15,384         | 3,699             |
| DNS          | 49         | 0.00         | 1,475          | 2,441             |
| TLS          | 36         | 0.00         | 2,160          | 1,440             |
| UDP          | 5          | 0.00         | 837            | 346               |
| HTTP         | 8          | 0.00         | 480            | 320               |
| <b>Razem</b> | <b>302</b> | <b>28.04</b> | <b>888,736</b> | <b>28,517,745</b> |

**Obserwacja:** Ruch Instagrama jest silnie zdominowany przez QUIC/HTTP/3.

#### 1.3.2 Największe cele (IP/port) wg wolumenu

TABELA 1.2: Największe kierunki ruchu (Instagram, ta sesja)

| IP docelowe    | Port | Proto | Flows | MiB   |
|----------------|------|-------|-------|-------|
| 185.60.217.63  | 443  | QUIC  | 137   | 27.52 |
| 157.240.251.63 | 443  | QUIC  | 1     | 0.33  |
| 185.60.217.3   | 443  | QUIC  | 35    | 0.08  |
| 185.60.217.20  | 443  | QUIC  | 2     | 0.02  |
| 185.60.217.175 | 5222 | TCP   | 11    | 0.02  |
| 157.240.251.11 | 443  | QUIC  | 1     | 0.02  |
| 185.60.217.28  | 443  | QUIC  | 1     | 0.01  |
| 157.240.0.63   | 443  | QUIC  | 1     | 0.01  |
| 185.60.217.13  | 443  | HTTPS | 2     | 0.01  |
| 157.240.253.17 | 443  | HTTPS | 1     | 0.01  |

**Obserwacja:** Największy wolumen koncentruje się na adresie 185.60.217.63 (serwer Meta, Dublin). Występują też długotrwałe połączenia TCP/5222 (port MQTT) do 185.60.217.175, związane najprawdopodobniej z powiadomieniami/czatem.

### 1.3.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.3: Top hosty (Instagram, liczba przepływów)

| Host                             | Flows |
|----------------------------------|-------|
| graph.instagram.com              | 138   |
| gateway.instagram.com            | 64    |
| z-p42-chat-e2ee-ig.facebook.com  | 35    |
| edge-mqtt.facebook.com           | 17    |
| i.instagram.com                  | 10    |
| graph.facebook.com               | 5     |
| i-fallback.instagram.com         | 5     |
| scontent-ber1-1.cdninstagram.com | 2     |
| static.xx.fbcdn.net              | 2     |
| lookaside.facebook.com           | 1     |

**Obserwacja:** Widoczna jest silna integracja z infrastrukturą Meta: poza domenami instagrama (graph, gateway, i.instagram.com) występują też hosty facebookowe (edge-mqtt, graph.facebook.com, lookaside).

### 1.3.4 Obserwacje jakościowe

- **Dominacja HTTP/3/QUIC.** Zdecydowana większość ruchu (liczebnie i wolumenowo) to QUIC na 443/UDP, co jest zgodne z trendem migracji warstwy mediów do HTTP/3 [2], [3].
- **Kanał utrzymania sesji.** Występuje równoległy kanał na **TCP/5222** (11–12 flows, mały wolumen), prawdopodobnie do komunikacji w czasie rzeczywistym/utrzymania połączenia.
- **Intensyfikacja przepływów po interakcji, następnie spadek aktywności.** Zliczenia per minuta (niezamieszczone tu dla zwięzłości) pokazują silny pik około 17:59 (setki nowych/kończących się flow), po którym następują krótkie sekwencje aktywności w tle ( $\approx$  18:05–18:06).
- **Niewielki ślad HTTP/1.1/HTTPS.** Jedynie kilka żądań; główna komunikacja i zasoby idą ścieżką QUIC.

### 1.3.5 Wyniki z Exodus Privacy [1]

Raport dla `com.instagram.android` (wersja 394.0.0.46.81, źródło Google Play) wykazał obecność **4 trackerów** oraz **69 uprawnień**.

#### Trackery.

- Facebook Flipper (analytics),
- Facebook Login (identification),
- Facebook Notifications,
- Google Analytics (analytics).

#### Uprawnienia — przykłady kluczowe:

- **Lokalizacja:** `ACCESS_FINE_LOCATION`, `ACCESS_MEDIA_LOCATION`,
- **Multimedia:** `CAMERA`, `RECORD_AUDIO`, `READ/WRITE_EXTERNAL_STORAGE`, `READ_MEDIA_IMAGES/VIDEO`,

- **Tożsamość/konta/telefonía:** GET\_ACCOUNTS, READ\_CONTACTS, READ\_CALL\_LOG, READ\_PHONE\_STATE, ANSWER\_PHONE\_CALLS,
- **Sieć i praca w tle:** ACCESS\_NETWORK\_STATE, WAKE\_LOCK, RECEIVE\_BOOT\_COMPLETED, FOREGROUND\_SERVICE\_\*.

*Uwaga:* pełna lista 69 uprawnień znajduje się w raporcie Exodusa (załącznik PDF/HTML).

### 1.3.6 Subiektywne spostrzeżenia

**Obserwowalność treści.** Podobnie jak w przypadku Facebooka, dominacja QUIC/HTTP/3 ( $\approx 99,8\%$  wolumenu) mocno ogranicza możliwość wglądu w treść ruchu.

**Zmienność wersji.** Instagram, podobnie jak Facebook, jest często aktualizowany. Hosty, udział QUIC i zestaw uprawnień mogą różnić się między wersjami i regionami. Wyniki dotyczą wersji 394.0.0.46.81.

### 1.3.7 Podsumowanie

W badanej sesji Instagram wykazuje:

1. niemal całkowitą dominację QUIC/HTTP/3 w wolumenie ( $\approx 99,8\%$ ),
2. intensywne użycie hostów `graph.instagram.com`, `gateway.instagram.com`, `chat-e2ee` (komunikacja, API, czat),
3. asymetrię RX/TX (27.2 vs 0.85 MiB) – użytkownik konsumował treści,
4. szerokie spektrum uprawnień (w tym lokalizacja, multimedia, telefonia) i obecność trackerów analitycznych.



## 1.4 Facebook (wersja 526.1.0.66.75)

### Okno i wolumen

Okno eksperymentu: **2025-08-19 19:24:12–19:36:29** ( $\approx 12.28$  min). Zarejestrowano **305** przepływów, wolumen  $\approx$  **29.75 MiB** (**RX  $\approx$  28.30 MiB, TX  $\approx$  1.45 MiB**).

#### 1.4.1 Wolumen i liczność wg protokołu

TABELA 1.4: Podsumowanie wg protokołu (Facebook, ta sesja)

| Protokół     | Flows      | MiB (total)  | B wysłane        | B odebrane        |
|--------------|------------|--------------|------------------|-------------------|
| QUIC         | 132        | 29.29        | 1,189,171        | 29,522,102        |
| TLS          | 93         | 0.01         | 5,620            | 3,768             |
| DNS          | 46         | 0.00         | 1,137            | 1,778             |
| HTTPS        | 19         | 0.43         | 312,835          | 142,702           |
| TCP          | 10         | 0.01         | 9,111            | 2,899             |
| HTTP         | 5          | 0.00         | 300              | 200               |
| <b>Razem</b> | <b>305</b> | <b>29.75</b> | <b>1,518,174</b> | <b>29,673,449</b> |

**Obserwacja:** Ruch Facebooka jest silnie zdominowany przez QUIC/HTTP/3 (jak u Instagrama).

#### 1.4.2 Największe cele (IP/port) wg wolumenu

TABELA 1.5: Największe kierunki ruchu (Facebook, ta sesja)

| IP docelowe    | Port | Proto | Flows | MiB   |
|----------------|------|-------|-------|-------|
| 185.60.217.28  | 443  | QUIC  | 50    | 25.46 |
| 157.240.210.14 | 443  | QUIC  | 1     | 2.01  |
| 185.60.217.20  | 443  | QUIC  | 79    | 1.79  |
| 185.60.217.3   | 443  | HTTPS | 2     | 0.20  |
| 157.240.210.16 | 443  | HTTPS | 8     | 0.15  |
| 157.240.210.3  | 443  | HTTPS | 3     | 0.03  |
| 185.60.217.13  | 443  | HTTPS | 2     | 0.02  |
| 185.60.217.28  | 443  | HTTPS | 1     | 0.02  |
| 157.240.0.13   | 443  | QUIC  | 1     | 0.01  |
| 31.13.91.40    | 443  | QUIC  | 1     | 0.01  |

**Obserwacja:** Największy wolumen koncentruje się na adresie 185.60.217.63 (serwer Meta, Dublin - jak u Instagrama).

### 1.4.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.6: Top hosty (Facebook, liczba przepływów)

| Host                            | Flows |
|---------------------------------|-------|
| graph.facebook.com              | 85    |
| lookaside.facebook.com          | 54    |
| chat-e2ee-mini.facebook.com     | 25    |
| gateway.instagram.com           | 24    |
| gateway.facebook.com            | 19    |
| edge-mqtt.facebook.com          | 14    |
| graph-fallback.facebook.com     | 14    |
| gateway-fallback.facebook.com   | 9     |
| edge-mqtt-fallback.facebook.com | 2     |
| *.fbcdn.net (różne)             | 5     |

**Obserwacja:** Analiza hostów pokazuje silną koncentrację ruchu na `graph.facebook.com` oraz powiązanych usługach (`lookaside`, `chat-e2ee-mini`, `gateway`). Wskazuje to na dominującą rolę centralnego API (`graph`) i serwisów pomocniczych (logowanie, czat, integracja z Instagramem). Dodatkowa obecność hostów typu `*-fallback` oraz `*.fbcdn.net` sugeruje stosowanie mechanizmów redundancji i serwerów CDN do dystrybucji treści multimedialnych.

### 1.4.4 Wyniki z Exodus Privacy (aplikacja)

Raport dla `com.facebook.katana` (wersja 525.0.0.53.51, Google Play) wskazuje obecność **8 trackerów** oraz **90 uprawnień**.

#### Trackery.

- Facebook Ads (advertisement),
- Facebook Audience (analytics),
- Facebook Flipper (analytics),
- Facebook Notifications,
- Facebook Places,
- Facebook Share,
- Google Analytics (analytics),
- Mapbox.

#### Uprawnienia — przykłady kluczowe:

- **Lokalizacja:** `ACCESS_COARSE_LOCATION`, `ACCESS_FINE_LOCATION`, `ACCESS_MEDIA_LOCATION`,
- **Multimedia:** `CAMERA`, `RECORD_AUDIO`, `READ/WRITE_EXTERNAL_STORAGE`, `READ_MEDIA_IMAGES/VIDEO`,
- **Tożsamość/konta/telefon:** `GET_ACCOUNTS`, `READ_CONTACTS`, `READ_PHONE_STATE`, `MANAGE_ACCOUNTS`,
- **Sieć i system:** `INTERNET`, `ACCESS_NETWORK_STATE`, `ACCESS_WIFI_STATE`, `NFC`, `WAKE_LOCK`, `SYSTEM_ALERT_WINDOW`,

- **Biometria i powiadomienia:** USE\_BIOMETRIC, USE\_FINGERPRINT, POST\_NOTIFICATIONS.

*Spostrzeżenia:*

- Zidentyfikowano szerokie spektrum trackerów, głównie od samego Facebooka, a także Google i Mapbox.
- Zakres uprawnień jest bardzo szeroki (90), obejmując zarówno krytyczne elementy systemowe (kamera, mikrofon, kontakty, lokalizacja), jak i dodatkowe funkcje (NFC, kalendarz).
- Liczba i charakter uprawnień odpowiada aplikacji działającej jako główna platforma społecznościowa, ale równocześnie rodzi poważne obawy o prywatność użytkowników.

**Uprawnienia — kategorie kluczowe.** Dla Facebooka istotne z perspektywy prywatności są zwłaszcza:

- **Lokalizacja:** ACCESS\_FINE\_LOCATION, ACCESS\_COARSE\_LOCATION (precyzyjna/przybliżona lokalizacja).
- **Multimedia:** CAMERA, RECORD\_AUDIO, dostęp do pamięci (READ/WRITE\_EXTERNAL\_STORAGE — jeśli występują w używanej wersji).
- **Tożsamość/konta/książka adresowa:** GET\_ACCOUNTS, READ\_CONTACTS.
- **Sieć/telefon i praca w tle:** ACCESS\_NETWORK\_STATE, WAKE\_LOCK, RECEIVE\_BOOT\_COMPLETED.

*Uwaga:* dokładny zestaw i liczba uprawnień zależą od wersji aplikacji i kanału dystrybucji; w raporcie Exodusa dla `com.facebook.katana` należy je cytować dla konkretnej wersji aplikacji poddanej badaniu.

#### 1.4.5 Subiektywne spostrzeżenia

**Obserwowalność treści.** Transport QUIC/UDP ogranicza klasyczne MITM/TLS-over-TCP; wgląd w semantykę HTTP jest bardzo ograniczony.

**Zmienność wersji.** Facebook to aplikacja o wysokiej dynamice wydawniczej; zestaw hostów, udział QUIC/H2 oraz uprawnienia mogą różnić się między wersjami i regionami. Liczby w tym rozdziale odnoszą się do konkretnej sesji i wersji aplikacji użytej w eksperymencie.

#### 1.4.6 Podsumowanie

W badanej sesji Facebook wykazuje:

1. dominację QUIC/HTTP/3 w wolumenie ( $\approx 98,5\%$ ),
2. charakterystyczne kanały usługowe (`graph/gateway/edge-mqtt`),
3. krótkotrwałe piki transferów związane z interakcjami użytkownika oraz ograniczoną aktywność w tle. Z perspektywy prywatności kluczowe są uprawnienia do lokalizacji, multimediów i pracy w tle oraz obecność komponentów analityczno-reklamowych.

## 1.5 Pośnania (wersja 1.1.1)

### Okno i wolumen

Okno eksperymentu: **2025-08-23 17:54:14–17:57:08** ( $\approx 2.9$  min). Zarejestrowano **21** przepływy, wolumen  $\approx$  **0.08 MiB** (RX  $\approx$  **0.06 MiB**, TX  $\approx$  **0.03 MiB**).

**Przebieg badania:** Scenariusz obejmował około **15 minut interakcji** z aplikacją, w tym: *start aplikacji, zmianę hasła, logowanie, dodanie rejestracji, nawigację po menu, wylogowanie, próbę błędnego logowania, ponowne logowanie, krótką pracę w trybie offline i online, ponowne wylogowanie oraz około 10 minut działania aplikacji w tle.*

### 1.5.1 Wolumen i liczność wg protokołu

TABELA 1.7: Podsumowanie wg protokołu (Pośnania, ta sesja)

| Protokół     | Flows     | MiB (total) | B wysłane     | B odebrane    |
|--------------|-----------|-------------|---------------|---------------|
| HTTPS        | 9         | 0.08        | 27,627        | 57,363        |
| DNS          | 12        | 0.00        | 260           | 468           |
| <b>Razem</b> | <b>21</b> | <b>0.08</b> | <b>27,887</b> | <b>57,831</b> |

**Obserwacja:** Ruch aplikacji jest w całości oparty o **HTTPS** (brak QUIC oraz HTTP w klarze).

### 1.5.2 Największe cele (IP/port) wg wolumenu

TABELA 1.8: Największe kierunki ruchu (Pośnania, ta sesja)

| IP docelowe    | Port | Proto | Flows | MiB  |
|----------------|------|-------|-------|------|
| 104.21.42.187  | 443  | HTTPS | 1     | 0.04 |
| 34.120.195.249 | 443  | HTTPS | 5     | 0.02 |
| 52.26.132.221  | 443  | HTTPS | 2     | 0.01 |
| 172.67.208.92  | 443  | HTTPS | 1     | 0.01 |
| 10.215.173.2   | 53   | DNS   | 12    | 0.00 |

**Obserwacja:** Cele to wyłącznie port **443/TCP** (HTTPS) oraz standardowe **DNS/53**. Brak nietypowych portów.

### 1.5.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.9: Top hosty (Pośnania, liczba przepływów)

| Host                               | Flows |
|------------------------------------|-------|
| api.yourb.app                      | 10    |
| o4505784913690624.ingest.sentry.io | 6     |
| m.stripe.com                       | 3     |
| updates.yourb.app                  | 2     |

**Obserwacja:** Widoczne są domeny **yourb.app** (API/aktualizacje), **sentry.io** (raportowanie błędów) oraz **stripe.com** (płatności).

#### 1.5.4 Obserwacje jakościowe

- **Brak QUIC/HTTP/3.** Cała komunikacja po 443/TCP (TLS).
- **Brak HTTP.** W badanej sesji nie obserwowano niezaszyfrowanych żądań HTTP.
- **Integracje zewnętrzne.** Ruch do `sentry.io` (crash reporting) i `stripe.com` (płatności) jest zgodny z funkcjonalnością aplikacji.

#### 1.5.5 Wyniki z Exodus Privacy [1]

Raport dla `com.yourbuildingapp.app.posnania` (wersja 1.1.1, Google Play) wskazuje obecność **1 trackera** (*Sentry* — crash reporting) oraz **18 uprawnień**.

**Uprawnienia — przykłady kluczowe:**

- **Kamera i multimedia:** CAMERA, READ\_EXTERNAL\_STORAGE, WRITE\_EXTERNAL\_STORAGE, READ\_MEDIA\_IMAGES, READ\_MEDIA\_VIDEO.
- **Tożsamość/telefon:** READ\_PHONE\_STATE.
- **Interfejs/system:** SYSTEM\_ALERT\_WINDOW, RECEIVE\_BOOT\_COMPLETED, SCHEDULE\_EXACT\_ALARM, POST\_NOTIFICATIONS.
- **Sieć:** INTERNET, ACCESS\_NETWORK\_STATE, ACCESS\_WIFI\_STATE.
- **Biometria:** USE\_BIOMETRIC, USE\_FINGERPRINT.

*Spostrzeżenia:* integracja z Sentry jest zgodna z profilem aplikacji, jednak szeroki zestaw uprawnień (kamera, biometria, alarmy systemowe) może być postrzegany jako nadmiarowy względem prostej funkcji aplikacji centrum handlowego.

#### 1.5.6 Subiektywne spostrzeżenia

**Obserwowalność treści.** Ze względu na TLS treści żądań/odpowiedzi nie są dostępne; brak oznak jawnego przesyłania danych.

**Hipotezy dot. bezpieczeństwa.** Podczas korzystania z aplikacji spostrzeżono możliwość wycieku informacji danych wrażliwych. Dodawanie tablic rejestracyjnych pojazdów nie wymaga wykazania własności samochodu. Dodać można każdą rejestrację, a następnie śledzić zarejestrowane na nią wjazdy i wyjazdy z parkingu. Na podstawie samego ruchu sieciowego *nie można* potwierdzić „otwartej”/słabo szyfrowanej bazy danych — wymaga to analizy on-device (np. SQLite/Room, manifest, reverse engineering APK) oraz testów dynamicznych (np. Frida, mitmproxy, sprawdzenie pinu certyfikatu).

#### 1.5.7 Podsumowanie

W badanej sesji Posnania wykazuje:

1. ruch wyłącznie po HTTPS (bez QUIC), niewielki wolumen ( $\approx 0.08$  MiB) i zapytania DNS,
2. integrację z `sentry.io` (telemetria błędów) i `stripe.com` (płatności),
3. brak śladów HTTP w klarze; dalsze badania wymagane, by ocenić bezpieczeństwo lokalnej bazy danych.

## 1.6 mObywatel (wersja 4.64.0 (4899))

### Okno i wolumen

Okno eksperymentu: **2025-08-24 13:23:03–13:26:00** ( $\approx 2.9$  min). Zarejestrowano **13** przepływy, wolumen  $\approx$  **0.21 MiB** (RX  $\approx$  **0.15 MiB**, TX  $\approx$  **0.06 MiB**).

**Przebieg badania:** Scenariusz obejmował około **15 minut interakcji** z aplikacją, w tym: *nasłuch tła (2 min)*, *logowanie (biometria + hasło)*, *wyświetlenie numeru PESEL*, *wgląd w dane wrażliwe (dowód, prawo jazdy, legitymacja studencka, dane pojazdu)*, *nawigacja po głównych ekranach (offline i online)*, *zamknięcie aplikacji oraz nasłuch tła (ok. 10 min)*.

### 1.6.1 Wolumen i liczność wg protokołu

TABELA 1.10: Podsumowanie wg protokołu (mObywatel, ta sesja)

| Protokół     | Flows     | MiB (total) | B wysłane     | B odebrane     |
|--------------|-----------|-------------|---------------|----------------|
| HTTPS        | 3         | 0.18        | 51,439        | 134,763        |
| TLS          | 4         | 0.02        | 13,802        | 10,017         |
| HTTP         | 1         | 0.01        | 630           | 8,157          |
| DNS          | 5         | 0.00        | 327           | 407            |
| <b>Razem</b> | <b>13</b> | <b>0.21</b> | <b>66,198</b> | <b>153,344</b> |

**Obserwacja:** Dominuje **HTTPS/TLS**; pojedynczy ślad **HTTP/80** dotyczy hosta Google (prawdopodobnie kontrola łączności/zasób systemowy) i nie wskazuje na przesyłanie treści aplikacyjnych w klarze.

### 1.6.2 Największe cele (IP/port) wg wolumenu

TABELA 1.11: Największe kierunki ruchu (mObywatel, ta sesja)

| IP docelowe     | Port | Proto | Flows | MiB  |
|-----------------|------|-------|-------|------|
| 185.41.93.206   | 443  | HTTPS | 3     | 0.18 |
| 185.32.48.239   | 3000 | TLS   | 4     | 0.02 |
| 142.250.203.195 | 80   | HTTP  | 1     | 0.01 |
| 10.215.173.2    | 53   | DNS   | 5     | 0.00 |

**Obserwacja:** Ruch koncentruje się na 443/TCP do usług państwowych; widoczny jest także kanał TLS na nietypowym porcie **3000** (telemetry/błędy).

### 1.6.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.12: Top hosty (mObywatel, liczba przepływów)

| Host                   | Flows |
|------------------------|-------|
| api.mobywatel.gov.pl   | 6     |
| sentry.puch.coi.gov.pl | 5     |
| www.gstatic.com        | 2     |

**Obserwacja:** `api.mobywatel.gov.pl` dominuje; `sentry.puch.coi.gov.pl` wskazuje na wewnętrzny system raportowania błędów; `www.gstatic.com` występuje pomocniczo (zasoby/kontrola łączności).

#### 1.6.4 Obserwacje jakościowe

- **Szyfrowanie transportowe:** właściwa komunikacja aplikacji po TLS/443; brak treści w klarze.
- **Brak QUIC/HTTP/3** w zarejestrowanym wycinku — kanał klasyczny TLS/TCP.
- **Telemetria:** obecność endpointu `sentry.puch.coi.gov.pl` (raportowanie błędów); wolumen niewielki.
- **HTTP/80 do Google:** pojedynczy flow (Google), typowy dla sprawdzeń łączności; brak wskazań na transfer danych aplikacji w klarze.

#### 1.6.5 Wyniki z Exodus Privacy [1]

Raport dla `pl.nask.mobywatel` (wersja 4.64.0 (4899), źródło Google Play) wskazuje **1 tracker** (*Sentry* — crash reporting) oraz **20 uprawnień**.

**Uprawnienia — przykłady kluczowe:**

- **Lokalizacja:** `ACCESS_COARSE_LOCATION`, `ACCESS_FINE_LOCATION`,
- **Multimedia/kamera/pamięć:** `CAMERA`, `READ_EXTERNAL_STORAGE`, `WRITE_EXTERNAL_STORAGE`,
- **Biometria:** `USE_BIOMETRIC`, `USE_FINGERPRINT`,
- **Telefonia/tożsamość:** `READ_PHONE_STATE`,
- **Sieć i usługi:** `INTERNET`, `ACCESS_NETWORK_STATE`, `ACCESS_WIFI_STATE`, `FOREGROUND_SERVICE`, `RECEIVE_BOOT_COMPLETED`, `WAKE_LOCK`, `NFC`, `POST_NOTIFICATIONS`, `GET_TASKS`,
- **Powiadomienia/FCM:** `RECEIVE`, `pl.nask.mobywatel.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION`.

*Spostrzeżenia:* brak większej ilości trackerów potwierdza szczególną wagę, jaką aplikacja przykładła do prywatności. Zestaw uprawnień jest szeroki, ale adekwatny do funkcji (obsługa dokumentów tożsamości, NFC, biometria).

#### 1.6.6 Subiektywne spostrzeżenia

**Obserwowalność treści.** Ze względu na TLS treści zapytań/odpowiedzi nie są dostępne; nie widać przesyłania danych wrażliwych w klarze.

**Praktyki bezpieczeństwa.** W analizowanym wycinku widać konsekwentne użycie HTTP-S/TLS do usług `*.gov.pl`, brak nietypowych punktów końcowych poza kanałem telemetrycznym (TLS/3000) i brak szerokich odwołań do domen trzecich. To zachowanie spójne z wysokim standardem bezpieczeństwa na warstwie transportowej. Pełna ocena (np. pinning certyfikatów, mechanizmy anti-tamper/anti-root, magazyn kluczy, ochrona ekranu) wymaga analizy APK oraz testów dynamicznych.

### 1.6.7 Podsumowanie

W badanej sesji mObywatel wykazuje:

1. dominację TLS/HTTPS; wolumen ( $\approx 0.21$  MiB), **13** przepływów w  $\sim 2.9$  min,
2. koncentrację ruchu na `api.mobywatel.gov.pl` oraz wewnętrzną telemetrię `sentry.puch.coi.gov.pl`,
3. pojedynczy flow HTTP/80 do zasobów Google (nie dotyczy danych wrażliwych aplikacji).



## 1.7 Mobile USOS (wersja 2.0.3)

### Okno i wolumen

Okno eksperymentu: **2025-08-24 13:43:09–13:47:29** ( $\approx 4.3$  min). Zarejestrowano **200** przepływów, wolumen  $\approx$  **2.88 MiB** (RX  $\approx$  **2.47 MiB**, TX  $\approx$  **0.40 MiB**).

**Przebieg badania:** Scenariusz obejmował około **15 minut interakcji** z aplikacją, w tym: *nasłuch tła (2 min)*, *logowanie*, *wyświetlenie numeru PESEL*, *wgląd w dane wrażliwe (PESEL, numer albumu)*, *wysłanie maila*, *nawigację po głównych ekranach (offline i online)*, *zamknięcie aplikacji (wylogowanie)* oraz *nasłuch tła (ok. 10 min)*.

### 1.7.1 Wolumen i liczność wg protokołu

TABELA 1.13: Podsumowanie wg protokołu (USOS, ta sesja)

| Protokół     | Flows      | MiB (total) | B wysłane      | B odebrane       |
|--------------|------------|-------------|----------------|------------------|
| HTTPS        | 173        | 2.87        | 421,868        | 2,592,198        |
| TLS          | 22         | 0.00        | 1,320          | 880              |
| DNS          | 5          | 0.00        | 360            | 725              |
| <b>Razem</b> | <b>200</b> | <b>2.88</b> | <b>423,548</b> | <b>2,593,803</b> |

**Obserwacja:** Ruch USOS w tej sesji jest zdominowany przez **HTTPS/TLS** (brak QUIC i brak HTTP w klarze).

### 1.7.2 Największe cele (IP/port) wg wolumenu

TABELA 1.14: Największe kierunki ruchu (USOS, ta sesja)

| IP docelowe     | Port | Proto | Flows | MiB  |
|-----------------|------|-------|-------|------|
| 150.254.5.110   | 443  | HTTPS | 25    | 0.91 |
| 216.58.208.206  | 443  | HTTPS | 5     | 0.90 |
| 142.250.186.196 | 443  | HTTPS | 14    | 0.54 |
| 150.254.5.52    | 443  | HTTPS | 126   | 0.51 |
| 142.250.186.42  | 443  | HTTPS | 2     | 0.01 |
| 142.250.203.131 | 443  | HTTPS | 1     | 0.01 |
| 150.254.5.52    | 3000 | TLS   | 20    | 0.00 |
| 150.254.5.110   | 3000 | TLS   | 2     | 0.00 |

**Obserwacja:** Największy wolumen kierowany jest do hostów na porcie **443/TCP** (HTTPS); widoczny jest też kanał **TLS/3000** o znikomym wolumenie (telemetria/błędy).

### 1.7.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.15: Top hosty (USOS, liczba przepływów)

| Host                                 | Flows |
|--------------------------------------|-------|
| usosapps.put.poznan.pl               | 147   |
| ppulse.put.poznan.pl                 | 28    |
| www.google.com                       | 14    |
| clients4.google.com                  | 6     |
| firebaseinstallations.googleapis.com | 3     |
| firebase-settings.crashlytics.com    | 2     |

**Obserwacja:** Dominują hosty uczelniane (usosapps.put.poznan.pl, ppulse.put.poznan.pl); obecne są też serwisy Google (instalacje Firebase, Crashlytics) oraz www.google.com (zasoby/kontrola łączności).

### 1.7.4 Obserwacje jakościowe

- **Brak QUIC/HTTP/3.** Komunikacja aplikacyjna po TLS/443; treść niedostępna.
- **Brak HTTP.** Nie odnotowano żądań nieszyfrowanych.
- **Integracje zewnętrzne.** Połączenia do usług Google (Firebase/Crashlytics) o małym wolumenie są zgodne z diagnostyką/aplikacyjną telemetrią.

### 1.7.5 Wyniki z Exodus Privacy [1]

Raport dla pl.edu.usos.mobilny (wersja 2.0.3, Google Play) wskazuje obecność **1 trackera** — *Google CrashLytics* (crash reporting) oraz **13 uprawnień**.

**Uprawnienia — przykłady kluczowe:**

- **Kamera/kalendarium:** CAMERA, READ\_CALENDAR, WRITE\_CALENDAR,
- **Biometria:** USE\_BIOMETRIC, USE\_FINGERPRINT,
- **Sieć/system:** INTERNET, ACCESS\_NETWORK\_STATE, NFC, POST\_NOTIFICATIONS, WAKE\_LOCK,
- **Inne:** CHECK\_LICENSE, RECEIVE (FCM), pl.edu.usos.mobilny.DYNAMIC\_RECEIVER\_NOT\_EXPORTED\_PERMISSION.

*Spostrzeżenia:*

- Exodus wykrywa sygnatury statyczne trackerów — nie jest to dowód ich aktywności w czasie działania.
- Jedyne tracker ma charakter czysto diagnostyczny; zestaw uprawnień obejmuje zarówno funkcje systemowe (NFC, notyfikacje), jak i elementy fakultatywne (kalendarz).

### 1.7.6 Subiektywne spostrzeżenia

**Obserwowalność treści.** Warstwa transportowa jest poprawnie szyfrowana (TLS); brak widoczności treści żądań/odpowiedzi oraz brak jawnego HTTP.

**Praktyki bezpieczeństwa.** W analizowanej sesji widać konsekwentne użycie **HTTPS/TLS** do hostów uczelnianych oraz ograniczoną telemetrię (Crashlytics/Firebase). Dalsza ocena (pinning certyfikatów, mechanizmy anti-root/anti-tamper, magazyn kluczy) wymaga analizy APK i testów dynamicznych.

### 1.7.7 Podsumowanie

W badanej sesji USOS wykazuje:

1. dominację TLS/HTTPS; wolumen ( $\approx 2.88$  MiB), **200** przepływów w  $\sim 4.3$  min,
2. koncentrację ruchu na hostach uczelnianych (`usosapps.put.poznan.pl`, `ppulse.put.poznan.pl`) oraz niewielką telemetrię do usług Google,
3. brak śladów HTTP w klarze oraz brak QUIC/HTTP/3 w zarejestrowanym oknie.

## 1.8 Spotify (wersja 9.0.72.967)

### Okno i wolumen

Okno eksperymentu: **2025-08-24 14:09:43–2025-08-24 14:11:57** ( $\approx 2.2$  min). Zarejestrowano **72** przepływy, wolumen  $\approx$  **12.42 MiB** (RX  $\approx$  **11.85 MiB**, TX  $\approx$  **0.58 MiB**).

**Przebieg badania:** Scenariusz obejmował: *logowanie, odtwarzanie kilku różnych utworów, przewijanie/seek, nawigację po ekranach głównych, wyszukiwanie, przeglądanie i edycję playlist (dodawanie utworów), wylogowanie.*

### 1.8.1 Wolumen i liczność wg protokołu

TABELA 1.16: Podsumowanie wg protokołu (Spotify, ta sesja)

| Protokół     | Flows     | MiB (total)  | B wysłane      | B odebrane        |
|--------------|-----------|--------------|----------------|-------------------|
| HTTPS        | 42        | 12.36        | 589,260        | 12,367,835        |
| TCP          | 5         | 0.06         | 10,391         | 49,839            |
| DNS          | 23        | 0.01         | 1,563          | 4,299             |
| MDNS         | 1         | 0.00         | 730            | 0                 |
| SSDP         | 1         | 0.00         | 1,530          | 0                 |
| <b>Razem</b> | <b>72</b> | <b>12.42</b> | <b>603,474</b> | <b>12,421,973</b> |

**Obserwacja:** Ruch Spotify jest zdominowany przez **HTTPS** (strumienie audio i zasoby CDN). W tym wycinku nie zaobserwowano QUIC; widoczny jest niewielki ślad **TCP** (kontrola/utrzymanie) oraz **DNS**, **mDNS** i **SSDP** (integracje urządzeń domowych).

### 1.8.2 Największe cele (IP/port) wg wolumenu

TABELA 1.17: Największe kierunki ruchu (Spotify, ta sesja)

| IP docelowe     | Port | Proto | Flows | MiB  |
|-----------------|------|-------|-------|------|
| 213.158.203.250 | 443  | HTTPS | 1     | 5.93 |
| 146.75.118.248  | 443  | HTTPS | 1     | 2.30 |
| 146.75.118.250  | 443  | HTTPS | 2     | 1.87 |
| 35.186.224.28   | 443  | HTTPS | 2     | 1.48 |
| 35.186.224.24   | 443  | HTTPS | 17    | 0.42 |
| 213.158.203.240 | 443  | HTTPS | 8     | 0.18 |
| 213.158.203.200 | 443  | HTTPS | 1     | 0.11 |
| 35.186.224.44   | 443  | HTTPS | 5     | 0.04 |
| 34.158.1.133    | 4070 | TCP   | 1     | 0.02 |
| 34.158.255.62   | 443  | TCP   | 1     | 0.01 |

**Obserwacja:** Największy wolumen trafia do adresów **\*.spotify.com/\*.spotifycdn.com** na **443/TCP** (CDN i API).

### 1.8.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.18: Top hosty (Spotify, liczba przepływów)

| Host                                | Flows |
|-------------------------------------|-------|
| spclient.wg.spotify.com             | 17    |
| image-cdn-ak.spotifycdn.com         | 9     |
| gew4-dealer.spotify.com             | 6     |
| ap-gew4.spotify.com                 | 4     |
| image-cdn-fa.spotifycdn.com         | 3     |
| gew4-spclient.spotify.com           | 3     |
| pickasso.spotifycdn.com             | 3     |
| ap-gue1.spotify.com                 | 2     |
| ap-guc3.spotify.com                 | 2     |
| firebaseanalytics-pa.googleapis.com | 2     |

**Obserwacja:** Widoczne są typowe domeny Spotify: `spclient.wg.spotify.com` (API/sterowanie), `spotifycdn.com` (okładki/zasoby), regionalne `gew*/ap-*` (dealery API). Okazjonalne żądania do `firebaseanalytics-pa.googleapis.com` wskazują na niewielką telemetrię.

### 1.8.4 Obserwacje jakościowe

- **Strumień audio po HTTPS** — w tym rzucie brak QUIC/HTTP/3; transport realizowany klasycznym TLS/TCP.
- **Integracje urządzeń** — obecność **mDNS/SSDP** sugeruje wykrywanie urządzeń w sieci lokalnej (Cast/AirPlay/Connect).
- **Asymetria RX/TX** — przewaga danych odbieranych ( 11.85 MiB) nad wysyłanymi ( 0.58 MiB), typowa dla odtwarzania multimediiów.

### 1.8.5 Wyniki z Exodus Privacy [1]

Raport dla `com.spotify.music` (wersja 9.0.72.967, Google Play) ujawnił **4 trackery** oraz **48 uprawnień**.

**Trackery:**

- **Branch** — atrybucja i linki dynamiczne,
- **ComScore** — pomiar oglądalności i statystyk,
- **Google CrashLytics** — diagnostyka i stabilność aplikacji,
- **Google Firebase Analytics** — analityka użycia.

**Uprawnienia (wybrane):**

- **Multimedia:** `RECORD_AUDIO`, `READ_MEDIA_AUDIO`, `WRITE_EXTERNAL_STORAGE`,
- **Łączność:** `BLUETOOTH_*`, `ACCESS_WIFI_STATE`, `CHANGE_NETWORK_STATE`,
- **Reklama i identyfikacja:** `AD_ID`, `ACCESS_AD SERVICES_AD_ID`.

*Spostrzeżenia:* obecność czterech trackerów odpowiada modelowi biznesowemu aplikacji muzycznej opartej na reklamie i analityce. Zakres uprawnień jest bardzo szeroki, obejmujący zarówno multimedia, jak i identyfikatory reklamowe.

### 1.8.6 Subiektywne spostrzeżenia

**Obserwowalność treści.** Zaszyfrowany strumień HTTPS uniemożliwia wgląd w treść audio lub zapytania API; analiza ogranicza się do metadanych (hosty, porty, wolumen).

**Uwagi dot. bezpieczeństwa.** Zachowanie sieciowe (TLS/443, brak jawnego HTTP, ograniczona telemetria) jest spójne z dojrzałą aplikacją medialną. Ocena pinningu certyfikatów, DRM czy mechanizmów anti-tamper wymaga analizy APK/testów dynamicznych.

### 1.8.7 Podsumowanie

W badanej sesji Spotify wykazuje:

1. dominację HTTPS ( $\approx 12.42$  MiB w **72** flow, okno 2.2 min),
2. koncentrację na hostach `*.spotify.com/*.spotifycdn.com` oraz aktywność mDNS/SSDP (urządzenia w sieci lokalnej),
3. zestaw trackerów i uprawnień zgodny z raportem Exodusa (4/48).

## 1.9 Voronoi (wersja 1.0.54)

### Okno i wolumen

Okno eksperymentu: **2025-08-24 14:31:51–2025-08-24 14:37:25** ( $\approx 5.6$  min). Zarejestrowano **465** przepływy, wolumen  $\approx$  **9.61 MiB** (**RX**  $\approx$  **9.21 MiB**, **TX**  $\approx$  **0.39 MiB**).

**Przebieg badania:** Scenariusz obejmował: *nasłuch tła (2 min)*, *utworzenie konta*, *logowanie*, *nawigację po ekranach (online/offline)*, *wyszukiwanie*, *wylogowanie*.

### 1.9.1 Wolumen i liczność wg protokołu

TABELA 1.19: Podsumowanie wg protokołu (Voronoi, ta sesja)

| Protokół     | Flows      | MiB (total) | B wysłane      | B odebrane       |
|--------------|------------|-------------|----------------|------------------|
| HTTPS        | 174        | 9.53        | 373,137        | 9,622,074        |
| TLS          | 226        | 0.06        | 33,132         | 33,984           |
| DNS          | 42         | 0.01        | 1,881          | 3,620            |
| TCP          | 23         | 0.00        | 2,420          | 2,144            |
| <b>Razem</b> | <b>465</b> | <b>9.61</b> | <b>410,570</b> | <b>9,661,822</b> |

**Obserwacja:** Ruch aplikacji jest zdominowany przez **HTTPS**; kanały **TLS/TCP** mają znikomy wolumen. Nie odnotowano QUIC ani jawnego HTTP.

### 1.9.2 Największe cele (IP/port) wg wolumenu

TABELA 1.20: Największe kierunki ruchu (Voronoi, ta sesja)

| IP docelowe   | Port | Proto | Flows | MiB  |
|---------------|------|-------|-------|------|
| 18.245.46.92  | 443  | HTTPS | 60    | 4.37 |
| 3.160.212.30  | 443  | HTTPS | 17    | 1.40 |
| 216.58.209.3  | 443  | HTTPS | 13    | 1.22 |
| 3.98.16.223   | 443  | HTTPS | 6     | 0.33 |
| 3.160.212.123 | 443  | HTTPS | 6     | 0.32 |
| 35.182.46.15  | 443  | HTTPS | 11    | 0.28 |
| 99.79.136.123 | 443  | HTTPS | 10    | 0.18 |
| 3.97.54.246   | 443  | HTTPS | 1     | 0.15 |

**Obserwacja:** Największy wolumen skupia się na 443/TCP do chmury (adresy AWS/Google) — typowe dla API/CDN aplikacji.

### 1.9.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.21: Top hosty (Voronoi, liczba przepływów)

| Host                                        | Flows |
|---------------------------------------------|-------|
| api.voronoiapp.com                          | 221   |
| cdn.voronoiapp.com                          | 182   |
| fonts.gstatic.com                           | 15    |
| firebase logging-pa.googleapis.com          | 14    |
| firestore.googleapis.com                    | 10    |
| cognito-identity.ca-central-1.amazonaws.com | 6     |
| crashlyticsreports-pa.googleapis.com        | 5     |
| cognito-idp.ca-central-1.amazonaws.com      | 4     |
| firebase-settings.crashlytics.com           | 2     |
| firebaseinstallations.googleapis.com        | 2     |

**Obserwacja:** Dominują domeny aplikacji (api.voronoiapp.com, cdn.voronoiapp.com); obecne są usługi Google Firebase/Crashlytics oraz Amazon Cognito (tożsamość).

### 1.9.4 Obserwacje jakościowe

- **Brak QUIC/HTTP/3** — transport klasyczny TLS/TCP po 443.
- **Brak HTTP w klarze** — w badanym oknie nie zaobserwowano nieszyfrowanych żądań.
- **Integracje zewnętrzne** — logowanie/konfiguracja przez cognito-identity/cognito-idp; telemetria do crashlytics; logowanie zdarzeń do firebase logging.

### 1.9.5 Wyniki z Exodus Privacy [1]

Raport dla com.voronoi.organization.app (wersja 1.0.34, Google Play) ujawniła obecność **3 trackerów** oraz **13 uprawnień**.

**Trackery:**

- **Facebook Share SDK** — integracja społecznościowa, potencjalnie przesyłająca metadane o interakcjach,
- **Google CrashLytics** — monitorowanie stabilności i raportowanie awarii,
- **Google Firebase Analytics** — analiza użycia aplikacji i zachowań użytkowników.

**Uprawnienia — przykłady kluczowe:**

- **Pamięć masowa:** READ\_EXTERNAL\_STORAGE, WRITE\_EXTERNAL\_STORAGE,
- **Reklama/atrybucja:** ACCESS\_AD SERVICES\_AD\_ID, ACCESS\_AD SERVICES\_ATTRIBUTION,
- **Sieć/system:** INTERNET, ACCESS\_NETWORK\_STATE, POST\_NOTIFICATIONS, READ\_GSERVICES,
- **Inne:** RECEIVE (FCM push).

*Spostrzeżenia:*

- Exodus bazuje na analizie statycznej APK — obecność trackerów oznacza włączenie ich bibliotek, ale nie przesądza o faktycznej aktywności w danej sesji.
- Zidentyfikowane trackery pełnią głównie rolę diagnostyczną i analityczną; zakres uprawnień jest stosunkowo wąski i dotyczy przede wszystkim pamięci, sieci oraz powiadomień.



### 1.9.6 Subiektywne spostrzeżenia

**Obserwowalność treści.** Szyfrowanie TLS ogranicza wgląd do metadanych; wolumen wskazuje na standardowe korzystanie z API/CDN (brak jawnego przesyłu danych wrażliwych).

**Uwagi dot. bezpieczeństwa.** Zachowanie sieciowe (HTTPS, brak plaintext, integracja z Cognito) jest spójne z typową architekturą: tożsamość w AWS Cognito, treści przez CDN/API. Pełna ocena (pinning certyfikatów, obsługa błędów TLS, polityka uprawnień w runtime) wymaga analizy APK/testów dynamicznych.

### 1.9.7 Podsumowanie

W badanej sesji Voronoi wykazuje:

1. dominację HTTPS ( $\approx 9.61$  MiB) w **465** flow, okno 5.6 min,
2. koncentrację na hostach aplikacji (`api.voronoiaapp.com`, `cdn.voronoiaapp.com`) i usługach Google/AWS (Firebase, Crashlytics, Cognito),
3. brak śladów QUIC i HTTP w klarze.

## 1.10 TikTok (wersja 34.8.4)

### Okno i wolumen

Okno eksperymentu: **2025-08-24 16:40:55–2025-08-24 16:45:00** ( $\approx 4.1$  min). Zarejestrowano **649** przepływy, wolumen  $\approx$  **125.30 MiB** (RX  $\approx$  **123.71 MiB**, TX  $\approx$  **1.59 MiB**).

**Przebieg badania:** Scenariusz obejmował: *2 min nasłuchu tła, tworzenie konta, logowanie, wylogowanie, nawigację po głównych stronach, lajkowanie, zmianę personalizacji treści, wyłączenie aplikacji oraz 10 min nasłuchu tła.*

#### 1.10.1 Wolumen i liczność wg protokołu

TABELA 1.22: Podsumowanie wg protokołu (TikTok, ta sesja)

| Protokół     | Flows      | MiB (total)   | B wysłane        | B odebrane         |
|--------------|------------|---------------|------------------|--------------------|
| QUIC         | 62         | 2.97          | 674,032          | 2,442,153          |
| HTTPS        | 156        | 122.24        | 960,142          | 127,220,147        |
| TCP          | 1          | 0.00          | 100              | 88                 |
| DNS          | 238        | 0.07          | 17,189           | 52,366             |
| TLS          | 190        | 0.02          | 12,237           | 7,919              |
| UDP          | 2          | 0.00          | 2,696            | 140                |
| <b>Razem</b> | <b>649</b> | <b>125.30</b> | <b>1,666,396</b> | <b>129,722,813</b> |

**Obserwacja:** Wolumen dominuje **QUIC/HTTP/3** (media po UDP/443); dodatkowo widoczne są **HTTPS/TCP** dla API oraz standardowe **DNS**. Brak jawnego HTTP.

#### 1.10.2 Największe cele (IP/port) wg wolumenu

TABELA 1.23: Największe kierunki ruchu (TikTok, ta sesja)

| IP docelowe     | Port | Proto | Flows | MiB   |
|-----------------|------|-------|-------|-------|
| 95.101.61.17    | 443  | HTTPS | 3     | 38.58 |
| 2.16.168.49     | 443  | HTTPS | 7     | 28.50 |
| 213.158.199.80  | 443  | HTTPS | 1     | 21.62 |
| 95.101.61.29    | 443  | HTTPS | 2     | 9.48  |
| 213.158.199.81  | 443  | HTTPS | 9     | 6.04  |
| 23.64.12.178    | 443  | HTTPS | 3     | 3.87  |
| 139.177.245.196 | 443  | QUIC  | 62    | 2.97  |
| 213.158.203.201 | 443  | HTTPS | 9     | 2.74  |
| 146.75.118.73   | 443  | HTTPS | 5     | 2.70  |
| 18.66.112.33    | 443  | HTTPS | 4     | 1.71  |

**Obserwacja:** Największy wolumen kierowany jest do CDN/edge ByteDance i Google (443/UDP i 443/TCP).

### 1.10.3 Najczęstsze hosty (liczba przepływów)

TABELA 1.24: Top hosty (TikTok, liczba przepływów)

| Host                                       | Flows |
|--------------------------------------------|-------|
| aggr32-normal.tiktokv.eu                   | 132   |
| libra16-normal-no1a.tiktokv.eu             | 41    |
| p16-common-sign-useastred.tiktokcdn-eu.com | 40    |
| v16m.tiktokcdn-eu.com                      | 32    |
| v19.tiktokcdn-eu.com                       | 20    |
| frontier16-normal-no1a.tiktokv.eu          | 20    |
| (brak)                                     | 19    |
| api16-normal-no1a.tiktokv.eu               | 16    |
| lf16-pitaya-pkg-sign.tiktokcdn-eu.com      | 13    |
| p77-sg.tiktokcdn.com                       | 10    |

**Obserwacja:** Typowe domeny: \*.tiktokv.eu/com, \*.tiktokcdn-eu.com, \*.byteoversea.com, \*.ibytedtos.com (media/CDN, API), mcs-\*/mon (telemetria), \*.googleapis.com (usługi pomocnicze).

### 1.10.4 Obserwacje jakościowe

- **Dominacja HTTP/3/QUIC** — strumień wideo po UDP/443; niskie RTT ustanawiania i dobra tolerancja strat.
- **Asymetria RX/TX** — silna przewaga danych odbieranych, zgodna z autoplay/scroll feedu.
- **Telemetria** — połączenia do hostów mcs-\*/mon-\*; wolumen niewielki względem mediów.

### 1.10.5 Wyniki z Exodus Privacy [1]

Raport dla com.ss.android.ugc.trill (wersja 34.8.4, Google Play) wskazuje obecność **5 trackerów** — *AppsFlyer* (analitika/atrybucja), *Facebook Login* (identyfikacja), *Facebook Share* (udostępnianie), *Google Firebase Analytics* (analitika) oraz *Pangle* (reklama) — oraz **44 uprawnień**.

**Uprawnienia** — przykłady kluczowe:

- **Lokalizacja i łączność:** ACCESS\_FINE\_LOCATION, ACCESS\_COARSE\_LOCATION, ACCESS\_NETWORK\_STATE, ACCESS\_WIFI\_STATE, BLUETOOTH\_CONNECT,
- **Multimedia:** RECORD\_AUDIO, CAMERA, READ\_MEDIA\_AUDIO/IMAGES/VIDEO,
- **Powiadomienia/system:** POST\_NOTIFICATIONS, FOREGROUND\_SERVICE, WAKE\_LOCK, SYSTEM\_ALERT\_WINDOW,
- **Reklama/identyfikacja:** ACCESS\_AD SERVICES\_AD\_ID, AD\_ID,
- **Pamięć:** READ/WRITE\_EXTERNAL\_STORAGE.

### 1.10.6 Subiektywne spostrzeżenia

**Obserwowalność treści.** Ze względu na QUIC/TLS treści żądań/odpowiedzi nie są widoczne; analiza dotyczy metadanych (hosty, porty, wolumeny).

**Uwagi dot. bezpieczeństwa.** Zachowanie sieciowe (HTTP/3 dla mediów, HTTPS/TCP dla API) jest typowe dla aplikacji wideo. Ocena pinningu certyfikatów, DRM i mechanizmów anti-tamper wymaga analizy APK oraz testów dynamicznych.

#### 1.10.7 Podsumowanie

W badanej sesji TikTok wykazuje:

1. dominację QUIC/HTTP/3 w wolumenie (media po UDP/443), przy API po HTTPS/TCP,
2. silną asymetrię RX/TX typową dla streamingu i przewijania feedu,
3. zestaw trackerów i szeroki zakres uprawnień zgodny z raportem Exodusa (5/44).

# Bibliografia

- [1] *Exodus Privacy: Analysis of trackers and permissions in Android apps*, <https://exodus-privacy.eu.org/>, Accessed 2025-08-17, 2025.
- [2] M. Bishop, *HTTP/3*, RFC 9114, 2022. adr.: <https://www.rfc-editor.org/rfc/rfc9114>.
- [3] *QUIC: A UDP-Based Multiplexed and Secure Transport*, RFC 9000, 2021. adr.: <https://www.rfc-editor.org/rfc/rfc9000>.



(2025)

Instytut Informatyki, Wydział Informatyki i Telekomunikacji  
Politechnika Poznańska

Skład przy użyciu systemu L<sup>A</sup>T<sub>E</sub>X (Overleaf).